

5 OWASP TOP 10 VULNERABILITIES

Course : CSDF

College : Shree LR Tiwari College Of Engineering

Report By- Mubasshera Zaidy

1. Broken Access Control

- What it is: Users can access data or actions beyond their permissions because authorization checks are missing or incorrect.
- Example: Changing a URL from /user/edit/123 to /user/edit/1 and accessing another user's account due to missing server-side checks (IDOR — Insecure Direct Object Reference).
- Impact: Unauthorized data exposure, privilege escalation, full account takeover.
- Prevention: Enforce server-side authorization on every request, validate resource ownership, use least-privilege RBAC, and avoid exposing sequential internal IDs.

2. Cryptographic Failures (formerly Sensitive Data Exposure)

- What it is: Sensitive data isn't properly encrypted or protected or cryptographic controls are misused.
- Example: Storing passwords in plaintext on an e-commerce site or using weak hashing without salt.
- Impact: Identity theft, financial fraud, legal violations (e.g., GDPR).
- Prevention: Use HTTPS, hash passwords securely (e.g., bcrypt), encrypt data in transit and at rest.

3. Injection Attacks

- What it is: Untrusted input is interpreted by an interpreter (SQL, NoSQL, OS shell, LDAP, XPath), allowing attackers to execute unintended commands.
- Example: SQL injection like 'OR '1'='1 to bypass login.
- Impact: Data theft, data modification, system compromise, unauthorized access.
- Prevention: Use parameterized queries / prepared statements, ORMs, strict input validation/whitelisting, and least-privilege DB accounts.

4. Insecure Design

- What it is: Architectural or design flaws (lack of threat modeling, insecure assumptions) that create systemic vulnerabilities.
- Example: No threat model for user flows, leading to insecure trust assumptions across components.
- Impact: Systemic vulnerabilities that can't be patched easily.
- Prevention: Apply secure design patterns, conduct threat modeling, use reference architectures.

5. Security Misconfiguration

- What it is: Improper settings or default configurations that expose systems.
- Example: Leaving admin panels exposed or using default credentials.
- Impact: Full system compromise, data leaks.
- Prevention: Harden configurations, automate security checks, remove unused features.